VE04 - Labor 1 - Crack the App

Der Patch-Zyklus (Befehls-Übersicht)

Vorbereitung:

- `adb devices` : Zur Kontrolle, ob der Emulator verbunden ist.
- `adb install [Original.apk]` : Um das Original vor dem Hack zu testen.
- `adb shell am start -n [Paketname]/.MainActivity` : App öffnen.
- `jadx-gui [Original-App.apk]` : Code lesbar machen, um die zu hackende Methode zu suchen.

① Dekodieren

- `apktool d -r -o [Zielordner-src] [Original-App.apk]` : Immer am Anfang (`-r` ist Optional, spart Zeit, weil Ressourcen nicht entpackt werden

② Smali-Code ändern

- Kein Befehl. Manuell in der `.smali`-Datei anpassen (z.b. `const/16 v0, 0x539`). (Ist immer nötig: Der eigentliche Hack).

③ Bauen (Packen)

- `apktool b [Zielordner-src] -o [App-unsigned.apk]` (Immer nach der Code änderung)

④ Ausrichtung (Alignment)

- `zipalign -P 16 -f 4 [App-unsigned.apk] [App-aligned.apk]` (Zwingend vor dem Signieren (Groß `-P 16` richtet native Bib. für den Speicher aus).

⑤ Schlüssel erstellen (Keystore)

- `keytool -genkeypair -keystore lab.keystore -alias lab -keyalg RSA -keysize 2048 -validity 3650 -storepass android -keypass android -dname "CN=MOBSEC Lab, O=Hochschule Heilbronn, C=DE"`

⑥ Signieren

- `apksigner sign --ks lab.keystore --ks-key-alias lab --ks-pass pass:android --key-pass pass:android --out [App-patched.apk] [App-aligned.apk]` (Signiert die ausgerichtete App mit deinem Schlüssel).

⑦ Prüfen (Verification)

- `apksigner verify --verbose --print-certs [App-patched.apk]` (Prüft, ob die Signatur gültig ist).
- `zipalign -c -P 16 -v 4 [App-patched.apk]` (Prüft danach nur lesend mit `-c`, ob die Ausrichtung noch intakt ist).

⑧ Alte App Löschen

- `adb uninstall [Paketname]`

⑨ Neuen Hack installieren und starten

- `adb install [App-patched.apk]` (Den Hack installieren).
- `adb shell am start -n [Paketname]/.MainActivity` (Den Hack starten).

Platzhalter

- `[Original-App.apk]` = Die Ursprungsdatei (z.b. helloworld.apk oder mensa.apk).
- `[Paketname]` = Der interne Name der App (z.b. de.hhn.mobsec.helloworld).
- `[Zielordner-src]` = Der Ordner, in den entpackt wird (z.b. highscore-src).
- `[App-unsigned.apk]` = Name nach dem Bauen (unsigniert).
- `[App-aligned.apk]` = Name nach dem Ausrichten.
- `[App-patched.apk]` = Die fertige App/Datei.